ทำไมความปลอดภัยของเว็บจึงสำคัญ?



85%+

การโจมตีทางไซเบอร์มุ่งเป้าที่ระดับแอปพลิเคชัน

ช่องโหว่บนระบบเว็บ คือ ประตูบานแรกสู่การเจาะระบบข้อมูลภายในองค์กร





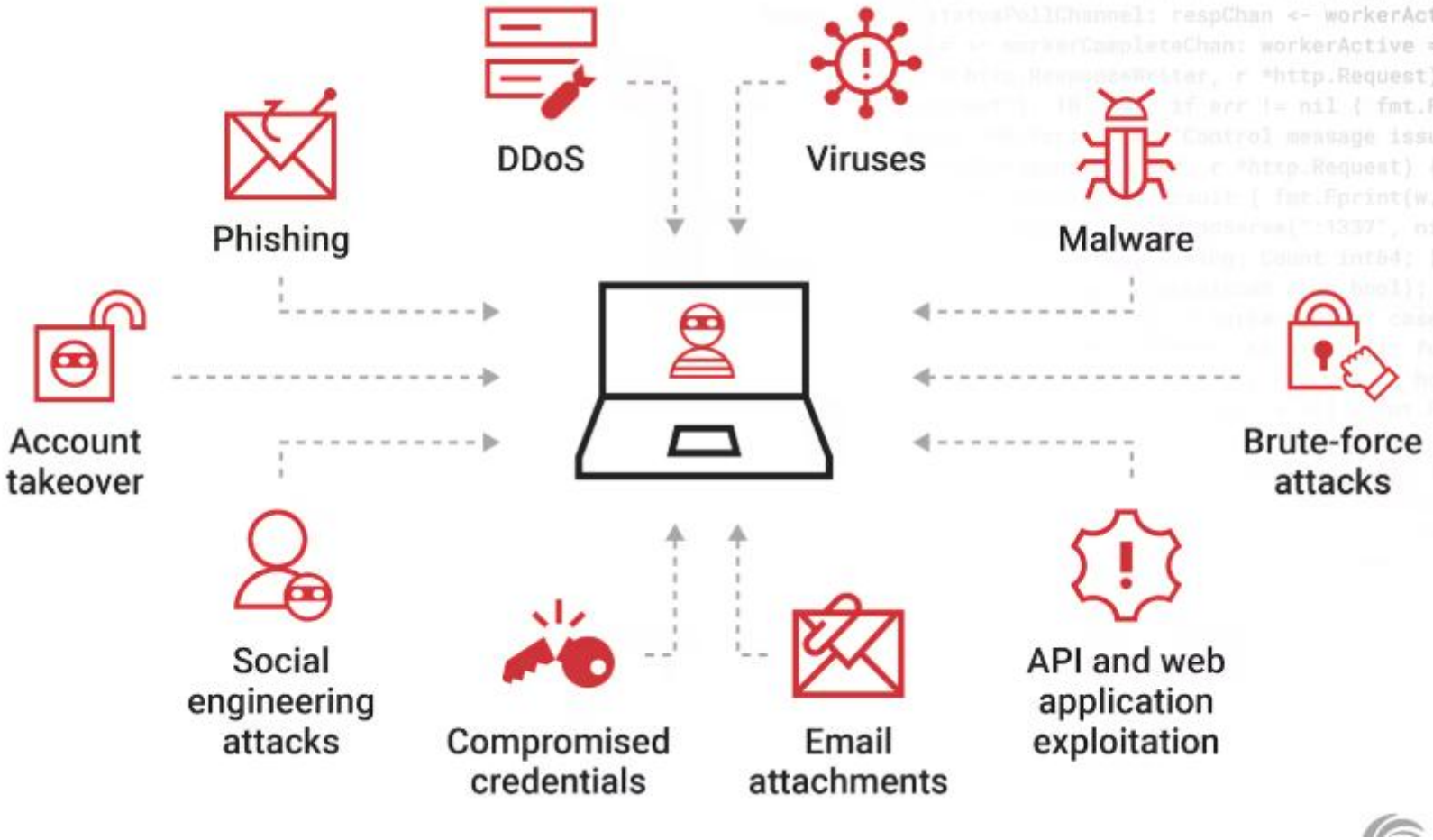
WEB Security

Web Security เป็นกระบวนการต่างๆ ที่มีจุดประสงค์ให้เว็บไซต์และประสบการณ์ผู้ใช้งานบนอินเทอร์เน็ตนั้นปลอดภัยจากการโจมตีทางไซเบอร์ประเภทต่างๆ เช่น การแฮ็กข้อมูล, ฟิชชิ่ง, เว็บไซต์ปลอม, และมัลแวร์ เป็นต้น การเขียนโปรแกรมที่ปลอดภัยนอกจากจะป้องกันข้อมูลของผู้ใช้งานแล้วยังช่วยรักษาชื่อเสียงและความไว้วางใจของบริษัทหรือแบรนด์ที่เจ้าของเว็บไซต์นั้นๆ

ผศ.รุ่ง หมูล้อม

WEB Security

- การรักษาความปลอดภัยของเว็บไซต์ คือ วิธีการและระบบที่ใช้ปกป้องเว็บไซต์จากภัยคุกคามทางไซเบอร์ เพื่อความปลอดภัยของข้อมูลผู้ใช้และความเสถียรของระบบ


DDoS
Viruses
Phishing
Malware
Account takeover
Brute-force attacks
Social engineering attacks
Compromised credentials
Email attachments
API and web application exploitation

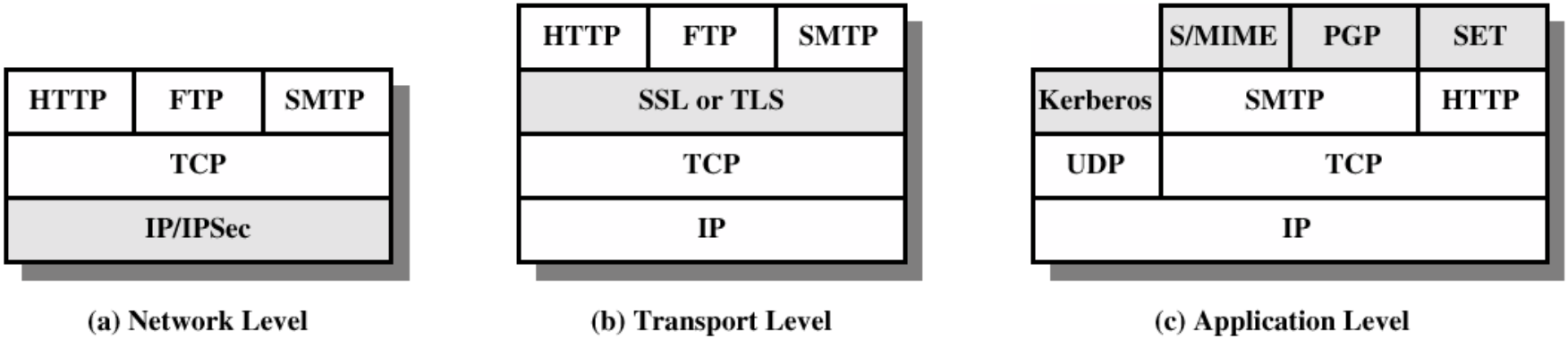
การพิจารณารักษาความปลอดภัยของเว็บ

- เว็บใช้กันอย่างแพร่หลายและทุกประเภทขององค์กร
- ซอฟต์แวร์ที่ซับซ้อนและซ่อนข้อมูลข้อบกพร่องด้านความปลอดภัยจะต่ำมาก
- เว็บเซิร์ฟเวอร์เป็นเรื่องง่ายที่จะกำหนดค่าและจัดการ
- ผู้ใช้เว็บจะไม่ตระหนักถึงความเสี่ยง “ผู้นั้น คือ เสี่ยง”
- มีความหลากหลายของการโจมตี ดังนั้นจึงต้องมีมาตรการรักษาความปลอดภัยเพิ่มเติม

ตารางแสดงการเปรียบเทียบภัยคุกคามบนเว็บ

ด้านความปลอดภัย	ภัยคุกคาม (Threats)	ผลกระทบที่เกิดขึ้น (Consequences)	มาตรการป้องกัน/รับมือ (Countermeasures)
ความถูกต้องสมบูรณ์ (Integrity)	• การดัดแปลงแก้ไขข้อมูลของผู้ใช้ • เบราว์เซอร์แฝงม้าโทรจัน • การดัดแปลงข้อมูลในหน่วยความจำ • การดัดแปลงแพ็กเกจข้อมูลขณะรับ-ส่งผ่านเครือข่าย	• สูญเสียความถูกต้องของข้อมูล • เครื่องคอมพิวเตอร์ถูกแทรกแซงหรือถูกยึดครอง • มีความเปราะบางและเปิดช่องโหว่ต่อภัยคุกคามอื่น ๆ ทั้งหมด	การใช้ผลรวมตรวจสอบเชิงรหัสลับ
การรักษาความลับ (Confidentiality)	• การดักฟังข้อมูลบนเครือข่ายอินเทอร์เน็ต • การขโมยข้อมูลจากเซิร์ฟเวอร์ • การขโมยข้อมูลจากเครื่องฝั่งผู้ใช้ (Client) • การดึงข้อมูลการตั้งค่าโครงสร้างเครือข่าย • การสอดแนมว่าผู้ใช้รายใดติดต่อกับเซิร์ฟเวอร์บ้าง	• สูญเสียข้อมูลสำคัญ • สูญเสียความเป็นส่วนตัว	การเข้ารหัสลับข้อมูล (Encryption), การใช้เว็บพร็อกซี (Web proxies)
การปฏิเสธการให้บริการ (Denial of Service - DoS)	• การสั่งยุติเธรดการทำงานของผู้ใช้ • การส่งคำขอปลอมจำนวนมหาศาลเพื่อถล่มเครื่องเป้าหมาย • การทำให้พื้นที่ดิสก์หรือหน่วยความจำเต็ม • การตัดขาดเครื่องเป้าหมายด้วยการโจมตีระบบ DNS	• รบกวนระบบและขัดขวางการทำงาน • สร้างความรำคาญใจ • กีดกันไม่ให้ผู้ใช้สามารถเข้าใช้งานหรือทำงานได้	ป้องกันได้ยาก (Difficult to prevent)
การพิสูจน์ตัวตน (Authentication)	• การสวมรอยเป็นผู้ใช้งานตัวจริง • การปลอมแปลงข้อมูล (Data forgery)	• การแอบอ้างสิทธิ์ตัวตนของผู้ใช้ที่ผิดพลาด • หลงเชื่อว่าข้อมูลปลอม/ข้อมูลเท็จเป็นข้อมูลจริงที่ถูกต้อง	การใช้เทคนิคเชิงรหัสลับ (Cryptographic techniques) เช่น Digital Signatures, Certificates

สิ่งอำนวยความสะดวกการรักษาความปลอดภัยใน TCP / IP protocol stack





SSL

- Secure Sockets Layer (SSL) คือ มาตรฐานเทคโนโลยีความปลอดภัยสำหรับการเข้ารหัสข้อมูล เพื่อสร้างการเชื่อมต่อที่ปลอดภัยระหว่างเว็บเซิร์ฟเวอร์และเบราว์เซอร์ ช่วยป้องกันไม่ให้แฮกเกอร์ขโมยหรือดักฟังข้อมูลสำคัญ เช่น รหัสผ่านหรือข้อมูลบัตรเครดิต

Secure Sockets Layer (SSL) คือ เทคโนโลยีความปลอดภัยทางอินเทอร์เน็ตที่ใช้เข้ารหัสข้อมูลระหว่างคอมพิวเตอร์ของผู้ใช้งานกับเว็บเซิร์ฟเวอร์เพื่อป้องกันการดักฟังหรือขโมยข้อมูล

การทำงานและประโยชน์

- เข้ารหัสข้อมูลแปลงข้อมูลส่วนตัวหรือรหัสผ่านให้เป็นรหัสลับระหว่างส่ง
- ยืนยันตัวตนตรวจสอบว่าเว็บไซต์นั้นเป็นของจริง ไม่ใช่เว็บปลอม
- สร้างความน่าเชื่อถือ: เปลี่ยนลิงก์จาก HTTP เป็น HTTPS และ แสดงรูปแม่กุหลาบที่เบราว์เซอร์

TLS

- Transport Layer Security (TLS) โปรโตคอลมาตรฐานความปลอดภัยทางไซเบอร์ที่ใช้เข้ารหัสข้อมูลระหว่างการสื่อสารบนอินเทอร์เน็ต เพื่อป้องกันไม่ให้แฮกเกอร์หรือผู้ไม่ประสงค์ดีดักฟัง (Eavesdropping) หรือแก้ไขข้อมูลที่รับ-ส่งกันระหว่างผู้ใช้กับเซิร์ฟเวอร์

เป็นโปรโตคอลหรือชุดคำสั่งความปลอดภัยบนอินเทอร์เน็ต ที่ทำหน้าที่เข้ารหัสข้อมูลระหว่างเครื่องผู้ใช้งาน (Client) กับเครื่องเซิร์ฟเวอร์ (Server) เพื่อป้องกันไม่ให้ข้อมูลถูกดักฟังหรือแก้ไขระหว่างทาง

หน้าที่หลักของ TLS

- เข้ารหัสข้อมูล (Encryption) แปลงข้อมูลให้อ่านไม่ออก หากมีคนดักจับได้ระหว่างทางก็จะไม่รู้ว่าเป็นข้อความอะไร
- ยืนยันตัวตน (Authentication) ตรวจสอบว่าเว็บไซต์หรือเซิร์ฟเวอร์ที่กำลังติดต่อด้วยนั้นเป็นของจริง ไม่ใช่เว็บปลอม
- รักษาความสมบูรณ์ของข้อมูล (Data Integrity) ป้องกันไม่ให้ข้อมูลถูกแอบแก้ไขหรือสอดแทรกระหว่างการรับส่ง

SSL and TLS

- They are transport layer security service.
- TLS working group was formed within IETF.
- First version of TLS can be viewed as an SSLv3.1.
- They use TCP for reliable end-to-end communication.

ความแตกต่างระหว่าง TLS กับ SSL

- SSL (Secure Sockets Layer) เป็นเทคโนโลยีรุ่นเก่า ที่ถูกเลิกใช้งานไปแล้ว เพราะมีช่องโหว่ด้านความปลอดภัย
- TLS เป็นเวอร์ชันใหม่ที่พัฒนาต่อยอด และมีความปลอดภัยสูงกว่ามาก แต่คนส่วนใหญ่ ยังนิยมเรียกติดปากรวมกันว่า SSL/TLS หรือเรียกใบรับรองว่า SSL Certificate
- ตัวอย่างที่เราเห็นได้ชัดเจน คือ การใช้งานเว็บไซต์ผ่าน HTTPS ซึ่งมีสัญลักษณ์รูปแม่กุญแจบนเบราว์เซอร์ หมายถึงเว็บไซต์นั้นมีการใช้งาน TLS คอยคุ้มครองความปลอดภัยอยู่

	SSL (Secure Sockets Layer)	TLS (Transport Layer Security)
สถานะปัจจุบัน	เลิกใช้งานแล้ว (ล้าสมัยและมีช่องโหว่)	เป็นมาตรฐานความปลอดภัยในปัจจุบัน
การพัฒนา	พัฒนาโดย Netscape ในปี 1995 (รุ่นสุดท้ายคือ 3.0)	พัฒนาต่อยอดโดย IETF (รุ่นปัจจุบัน คือ 1.3)
ความเร็วในการทำงาน	ช้ากว่าเมื่อทำการเชื่อมต่อครั้งแรก (Handshake)	เร็วและมีประสิทธิภาพมากกว่า (ลดขั้นตอน Handshake)
ความปลอดภัย	มีช่องโหว่ ถูกแฮกได้ง่าย	มีความปลอดภัยสูงมาก เข้ารหัสข้อมูลระดับสูง

SSL Architecture

SSL is a two-layer protocol not a just single protocol.

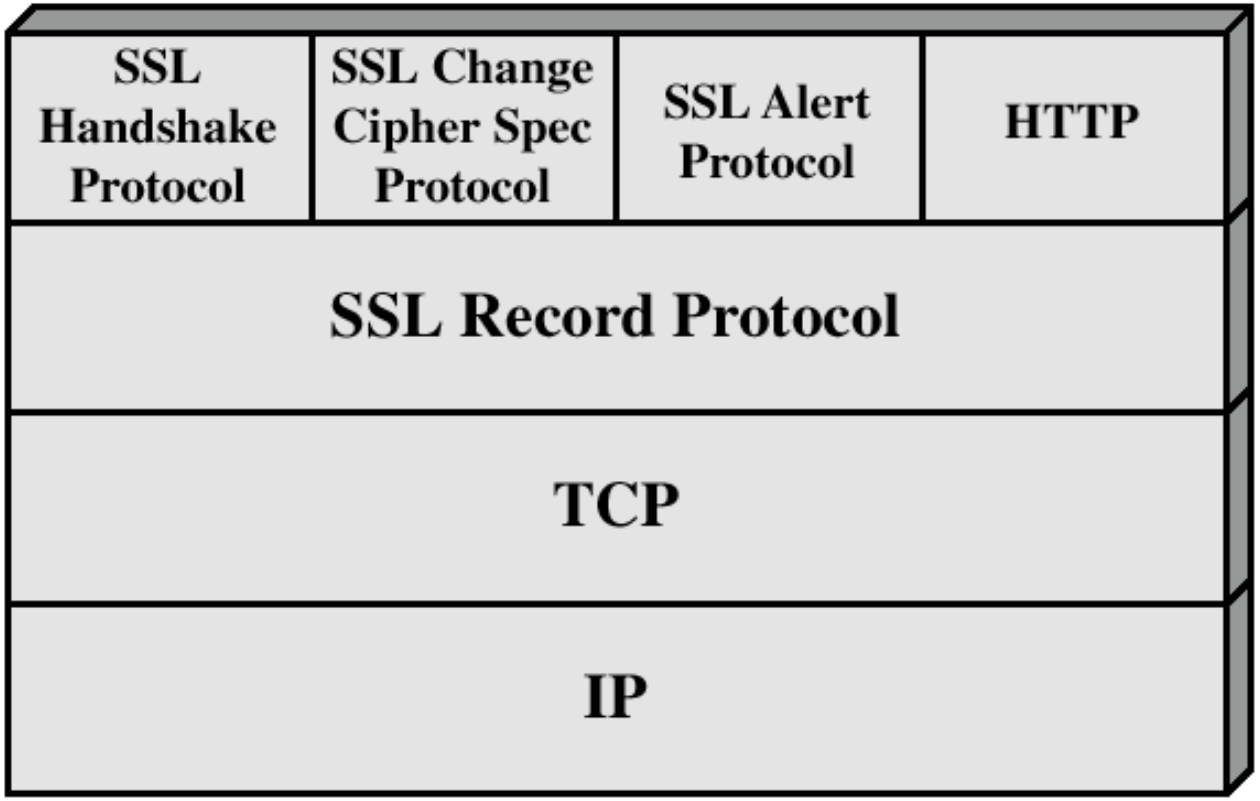


Figure 7.2 SSL Protocol Stack

Two Important Concepts

- **SSL session**
  - an association between client & server
  - created by the Handshake Protocol
  - define a set of cryptographic (ชุดของการเข้ารหัสลับ) parameters
  - may be shared by multiple SSL connections
- **SSL connection**
  - a transient(ชั่วคราว), peer-to-peer, communications link
  - associated with one SSL session

Session กำหนดโดย

- Session identifier
- Peer certificate(รับรอง)
- Compression method
- Cipher spec
- Master secret: 48 byte secret shared between client and server
- Is resumable: a flag indicating whether new connections can be initiated

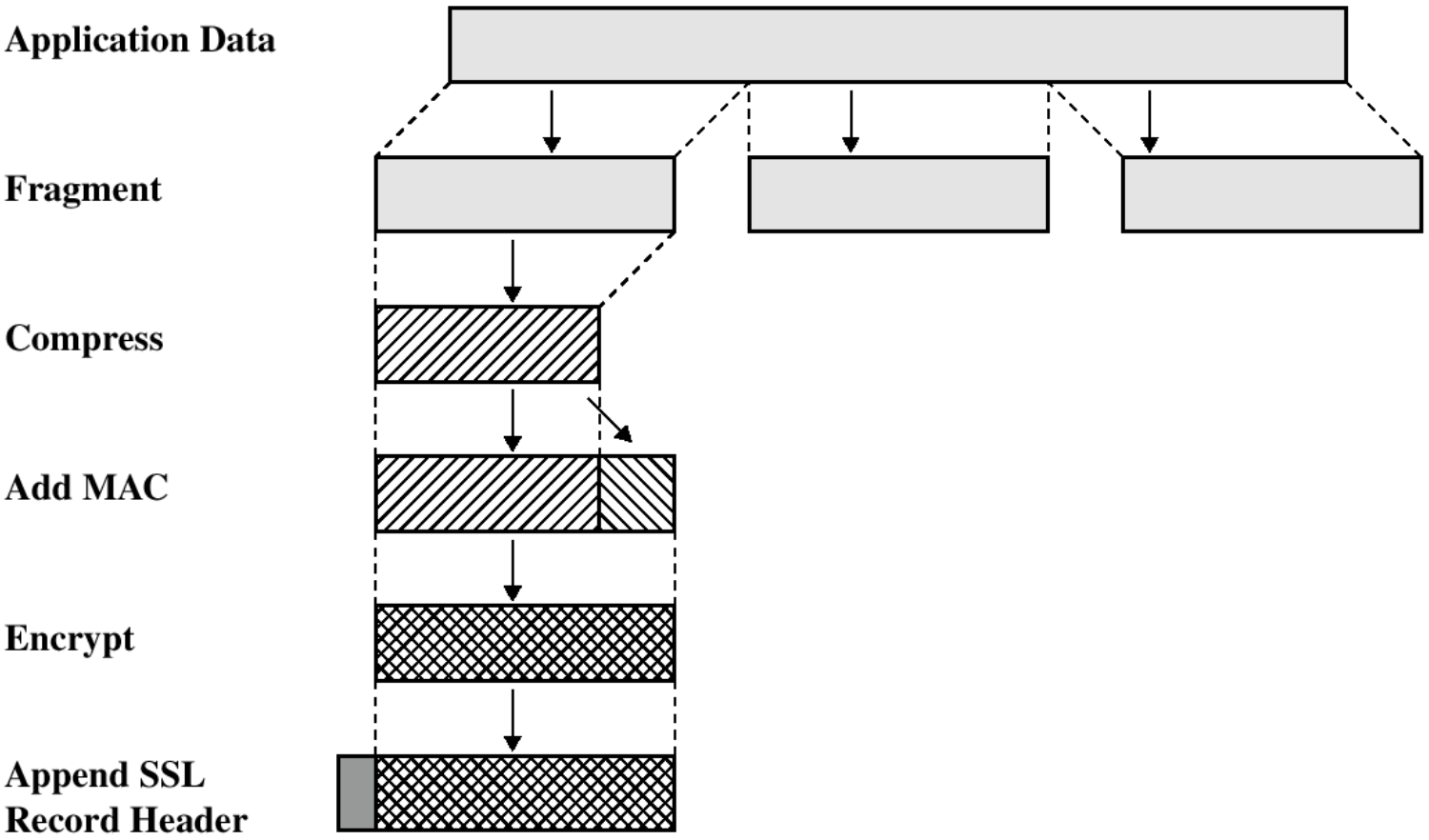
Connection กำหนดโดย

- Server and Client random to identify connection
- Server and Client write MAC secrets
- Server and Client write keys
- Initialization Vector (IV)
- Sequence numbers maintained separately by each part for transmitted and received messages

SSL Record Protocol

- **Confidentiality**
  - using symmetric encryption with a shared secret key defined by Handshake Protocol
  - IDEA, RC2-40, DES-40, DES, 3DES, Fortezza, RC4-40, RC4-128
  - message is compressed before encryption
- **Message integrity**
  - using a MAC with shared secret key
  - similar to HMAC but with different padding

SSL Record Protocol Operation

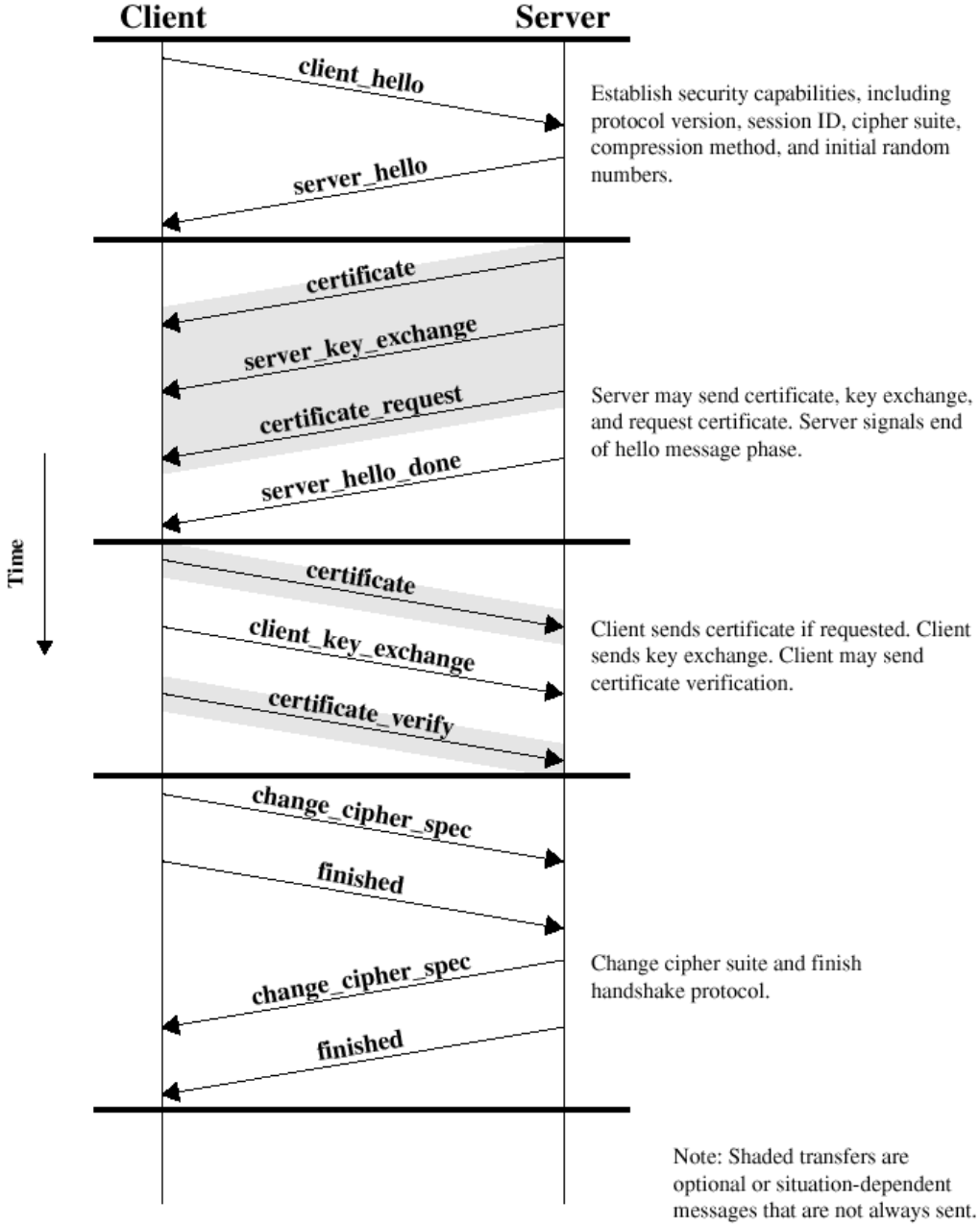


(Handshake Protocol)

โปรโตคอลจับมือ (Handshake Protocol) หมายถึง กระบวนการที่ผู้เข้าร่วมสองคนในเซสชัน TLS เจรจาและสร้างรหัสลับหลักที่ใช้ร่วมกัน ซึ่งใช้ในการสร้างคีย์หลายชุดเพื่อความสมบูรณ์ของข้อมูล การรักษาความลับ และการสร้างคีย์เซสชัน การเจรจานี้ประกอบด้วยการเลือกอัลกอริทึมการเข้ารหัส

กระบวนการเตรียมความพร้อมหรือ "การทักทาย" เบื้องต้นระหว่างอุปกรณ์สองเครื่องในเครือข่ายคอมพิวเตอร์ เพื่อตรวจสอบตัวตน ตกลงเงื่อนไขการสื่อสาร และสร้างการเชื่อมต่อที่ปลอดภัย ก่อนที่จะเริ่มส่งข้อมูลจริง

Handshake Protocol Action



แนวทางปฏิบัติที่ดีที่สุดด้านความปลอดภัยบนเว็บ

- ใช้งาน HTTPS โปรโตคอลการถ่ายโอนไฮเปอร์เท็กซ์ที่ปลอดภัย (HTTPS)
- **การอัปเดตและการแก้ไขช่องโหว่ของระบบ**
- **รหัสผ่านที่ปลอดภัย**
- **การตรวจสอบสิทธิ์แบบหลายปัจจัย การยืนยันตัวตนแบบหลายปัจจัย (MFA):** บังคับใช้การยืนยันตัวตนมากกว่าหนึ่งขั้นตอน เช่น รหัสผ่านร่วมกับรหัส OTP เพื่อป้องกันการเจาะระบบ
- **การสำรองข้อมูลบ่อยครั้ง**
- **ติดตั้งระบบป้องกันการโจมตี** เช่น เว็บแอปพลิเคชันไฟร์วอลล์ เพื่อบล็อกการจู่โจมจากผู้ไม่ประสงค์ดี